Privacy and Personal Data Handling Policy

Document ID	SEC-014
Department	IT and Information Security
Document type	Policy
Owner	Privacy Officer
Version	4.3
Status	APPROVED
Effective / last reviewed	2025-09-15
Audience	All employees and contractors
Related documents	SEC-005, SEC-010, SEC-011, CS-007

Summary. Policy governing how Northstar Systems collects, uses, shares, retains and protects personal data of employees, candidates, customers and their users, including purpose limitation, data subject requests within 30 days, impact assessments, processor agreements and personal-data breach reporting to the Privacy Officer.

SYNTHETIC DOCUMENT - Northstar Systems is a fictional company. This document exists for development, testing and demonstration only and is not real legal, employment, security or compliance advice.

1. Purpose and Scope

This policy sets out how Northstar Systems Private Limited ("Northstar") handles personal data. Personal data means any information that identifies, or can reasonably be linked to, a living individual, such as a name, email address, Employee ID (NS- followed by five digits), phone number, bank details, IP address, photograph or a customer end user's identifiers held in the Northstar Nexus Platform. The policy applies to all employees, contractors, interns and third parties who process personal data on behalf of Northstar, in every system, including NorthPeople, NorthPay, NorthAssist, NorthDesk, NorthBuy, email, shared drives and customer environments of the Northstar Nexus Platform.

Any reference in this policy to a statute, regulation or regulatory deadline is illustrative and must be verified by Legal before external use. The policy follows a data-protection approach modelled on the Indian Digital Personal Data Protection regime, but internal rules in this policy apply whether or not a statute requires them.

The policy covers three groups of individuals:

- Employees, contractors and candidates (internal personal data).
- Customer contacts and users of Northstar products who interact with NorthAssist or the websites (customer personal data).
- Personal data that Northstar customers place in their own Nexus Workspaces, Pipelines and Connectors, for which Northstar normally acts as a processor.

2. Definitions

- **Data principal or data subject:** the individual the personal data is about.
- **Controller:** the party that decides why and how personal data is processed. Northstar is the controller for employee and candidate data and for its own customer-relationship data.

- **Processor:** a party that processes personal data on behalf of a controller. Northstar is usually a processor for the personal data its customers load into the Nexus Platform, and its vendors are processors when they handle Northstar's personal data.
- **Sensitive personal data:** personal data whose loss would cause serious harm, such as financial account details, government identifiers, health information, biometrics and credentials. Northstar classifies this as Restricted under SEC-005.
- **Processing:** any operation on personal data, including collecting, storing, viewing, sharing, analysing or deleting it.
- **Privacy Officer:** the officer, reporting to the General Counsel, who owns this policy and decides on personal-data breach notifications.
- **DPIA:** Data Protection Impact Assessment.
- **DPA:** Data Processing Agreement.
- **DSAR:** data subject access request.

3. Roles and Responsibilities

Role	Responsibility
Privacy Officer	Owns this policy, handles data subject requests, triages correction and erasure requests, approves DPIAs, decides personal-data breach notifications
General Counsel	Oversees the Privacy Officer, approves DPA templates, advises on legal obligations
CISO and SIRT	Secure the systems that hold personal data, run incident response (see SEC-010)
Department heads	Ensure their teams process only necessary data and keep their records of processing current
System owners	Maintain access controls, retention settings and deletion routines for their systems
Procurement	Ensure a DPA is signed before any personal data is shared with a vendor
All employees	Handle personal data only for approved purposes and report breaches immediately

4. Core Principles

Every processing activity must follow these principles.

1 **Necessity.** Collect only the personal data that is necessary for the stated purpose. If a field is not needed, do not collect it. A form that asks for date of birth when only age eligibility matters should ask only for a yes or no answer.

2 **Documented purpose.** Every purpose must be documented in the Record of Processing Activities (RoPA) kept by the Privacy Officer. Data collected for one purpose must not be reused for an unrelated purpose without a fresh review and, where required, fresh consent.

3 **Notice and consent.** Individuals must be told what is collected, why, how long it is kept and whom it is shared with. Where consent is the legal basis, it must be freely given, specific and capable of being withdrawn as easily as it was given.

4 **Accuracy.** Personal data must be kept accurate and updated when the individual tells us it has changed.

5 **Storage limitation.** Personal data must be deleted or anonymised when the retention period in SEC-005 ends, unless a legal hold applies.

6 **Security.** Personal data must be protected by the controls in the security policies, in particular encryption, access control and logging.

7 **Accountability.** Northstar must be able to show how it complies, through records, assessments and audits.

5. Collection and Use

5.1 Employee and candidate data

HR (People Team) collects personal data for recruitment, onboarding, payroll, benefits, performance management and statutory compliance. Typical items include identity proof, address, bank details, emergency contacts, educational and employment history, background verification results and health insurance dependants. This data is Restricted. Access is limited to HR, Payroll staff in NorthPay, the employee's reporting manager (for work-related information only) and others with a documented need.

Recruitment records of unsuccessful candidates are kept for 12 months and then deleted. Employee records are kept for 7 years after exit and payroll records for 8 years, as set out in SEC-005.

Example: A recruiter in Bengaluru wants to keep the CVs of rejected candidates for future openings beyond the 12-month period. The recruiter must instead ask the candidate for fresh consent to be contacted again; without consent the CV must be deleted after 12 months.

5.2 Customer and end-user data

Customer-relationship data, such as names, business email addresses and phone numbers of customer contacts held in NorthAssist, is Confidential. Support tickets are retained for 5 years after closure. Support staff must not ask customers to send personal data of end users in tickets. If a customer attaches such data, the engineer must remove or mask it from the ticket where possible and tell the customer how to share diagnostic information safely.

Customer production data inside the Nexus Platform is Restricted. Northstar staff may access it only for a documented support or incident purpose, with a NorthDesk ticket and through the controlled access routes described in SEC-002, and the access is logged under SEC-015.

5.3 Website, marketing and analytics

Marketing must obtain consent before using non-essential cookies and before sending marketing email to individuals. An unsubscribe link must be present in every marketing message and unsubscribe requests must be honoured within 5 business days. Analytics data should be aggregated or pseudonymised wherever possible.

5.4 Monitoring of staff

Monitoring of corporate systems is carried out for security and compliance as described in SEC-015. Staff must be told what is monitored. Monitoring content of personal messages or personal devices is not permitted.

5.5 CCTV

CCTV footage at Northstar offices is kept for 30 days and then overwritten, unless footage is needed for an investigation. Access to footage requires approval from the Head of Facilities and the Privacy Officer.

6. Sharing and Transfers

Personal data may be shared inside Northstar only with people who need it for their role. It may be shared outside Northstar only when one of these conditions holds:

- The individual has been informed and, where required, has consented.
- The recipient is a processor bound by a signed DPA.
- The disclosure is required by law and Legal has approved it.

A DPA must be signed before any personal data is shared with a vendor. Procurement must not issue a purchase order for a service that will process personal data until Legal confirms the DPA is in place (see OPS-003 and SEC-011). The DPA must cover purpose and instructions, confidentiality, security measures, sub-processors, assistance with data subject requests, breach notice to Northstar, return or deletion at the end of the contract, and audit rights.

Personal data must never be sent through personal email or external AI tools. Restricted data must be encrypted at rest and in transit and shared only through approved tools.

Cross-border transfers of personal data, including access by a vendor's support team located outside India, must be reviewed by the Privacy Officer and Legal before they begin. Primary hosting of customer data is in the Mumbai region with disaster recovery in Hyderabad; moving personal data to any other region needs written approval from the Privacy Officer.

7. Rights of Individuals

Individuals may ask Northstar to confirm what personal data it holds about them, give them a copy, correct it, erase it, or restrict certain uses. They may also withdraw consent and raise a complaint.

7.1 How requests are received

An employee, candidate or customer may send a request to the Privacy Officer, to the HR Helpdesk (for employees) or through NorthAssist (for customers). Any employee who receives a request in any channel must forward it to the Privacy Officer on the same business day. Staff must not ignore, reject or answer a request on their own.

7.2 Handling steps and deadlines

1 The Privacy Officer logs the request and confirms the requester's identity using information Northstar already holds. Do not ask for more identity documents than necessary.
2 The Privacy Officer identifies the systems involved and asks system owners to gather the data. System owners must respond within 7 working days.
3 The Privacy Officer reviews the data, removes information about other individuals and legally privileged material, and prepares the response.
4 Access requests (DSARs) must be answered within 30 days of receiving the request. If the request is complex, the Privacy Officer may extend the period once, tells the requester before the 30 days end, and records the reason.
5 Correction and erasure requests are triaged by the Privacy Officer. Corrections to simple fields, such as an address in NorthPeople, are carried out promptly. Erasure is refused or limited where a legal hold applies or where law requires the data to be retained, such as payroll and tax records held for 8 years. The requester must be told the reason.

Example: A former employee, who left 2 years ago, asks HR to delete all personal data. The Privacy Officer replies within 30 days, explains that employee records must be retained for 7 years after exit and payroll records for 8 years, deletes data that has no retention requirement (such as marketing preferences) and confirms when remaining data will be deleted.

7.3 Requests about customer end users

When an end user of a customer asks Northstar for their data held in the Nexus Platform, Northstar acts as a processor. The request must be passed to the customer, who is the controller, within 5 business days unless the contract states otherwise. Northstar must not respond to the individual directly with personal data.

8. Data Protection Impact Assessments

A DPIA is mandatory before starting any new high-risk processing. A processing activity is high-risk if any of the following applies:

- Large-scale processing of Restricted personal data, such as launching a new payroll or benefits system.
- Profiling or automated decisions that significantly affect individuals.
- Use of biometric data, for example for office access.
- Systematic monitoring of individuals.
- Use of a new vendor or technology, including AI features, that processes personal data in a new way.
- Moving personal data to a new region.

The project owner completes the DPIA template, describing the purpose, the data, the flows, the risks and the proposed controls. The Privacy Officer reviews it within 10 business days of receiving a complete form, and may approve it, approve it with conditions or reject it. Work on the new processing must not go live until the DPIA is approved. High residual risks go to the CISO and General Counsel.

9. Security of Personal Data

All personal data must be protected using the controls in SEC-005 and SEC-002. In particular:

- Restricted personal data must be encrypted at rest (AES-256) and in transit (TLS 1.2 minimum).
- Access is role-based and least privilege, reviewed quarterly.
- Production customer data must not be copied to laptops, test environments or spreadsheets. If test data is needed, it must be masked or synthetic.
- Exports of personal data from NorthPeople, NorthPay or NorthAssist must be approved by the system owner and logged.
- Personal data in logs must be minimised. Application logs must not contain passwords, tokens, or full government identifiers.
- Access to personal data is logged and reviewed in line with SEC-015.

10. Personal Data Breach Handling

A personal-data breach is any event that leads to accidental or unlawful loss, alteration, unauthorised disclosure of or access to personal data. Examples include an email with a salary file sent to the wrong recipient, a lost laptop holding customer exports, a misconfigured storage bucket, or a vendor reporting a compromise.

1 **Report immediately.** Anyone who discovers or suspects a breach must report it at once to the Privacy Officer and to the Security Desk (ext. 5555 or security@northstar-systems.example). Do not wait to confirm the facts or the scale.

2 **Contain.** The SIRT, led by the Incident Response Lead, contains the incident following SEC-010. Preserve evidence; forensic evidence is kept for 12 months.
3 **Assess.** The Privacy Officer assesses what data was affected, how many individuals, how sensitive the data is, and the risk of harm.
4 **Decide on notification.** The Privacy Officer decides whether individuals or regulators must be notified, in consultation with Legal. Any regulatory deadline, for example a 6-hour reporting window for specified incident types, is illustrative and must be verified by Legal before use.
5 **Customer notification.** Where a confirmed breach affects customer data, the affected customer must be notified within 72 hours of confirmation, as set out in customer contracts (illustrative).
6 **Review.** After closure, the Privacy Officer and CISO review the root cause and track corrective actions.

Employees must not contact regulators, customers or the press about a breach themselves. Messages to customers follow the communication library and must not include internal system names or personal data.

Example: A Payroll Analyst emails the May salary sheet for 480 employees to an external address by mistake. The analyst reports it to the Privacy Officer and the Security Desk within minutes, asks the recipient to delete the file, and the SIRT checks mail logs. The Privacy Officer decides that employees must be informed and records the corrective action, which is to enable external-recipient warnings on payroll mailboxes.

11. Third Parties and Processors

Vendors that handle personal data are assessed under SEC-011 and selected under OPS-003. Before any personal data is shared the vendor must have a signed DPA and, for Critical and High risk vendors, a completed security assessment. Vendors must notify Northstar of any personal-data breach without undue delay, and in any case within 24 hours of becoming aware. Sub-processors need Northstar's prior written approval. At contract end, the vendor must return or securely delete the data and provide a deletion certificate.

12. Training and Awareness

All employees complete security and privacy awareness training within 14 days of joining and refresh it annually (see SEC-012). HR staff, Payroll, Support and Data Engineering staff must complete additional privacy training each year because they handle large volumes of personal data.

13. Exceptions and Escalation

Exceptions to this policy may be approved only by the Privacy Officer in writing, with CISO agreement where security controls are affected, and for a maximum of 90 days. Questions can be sent to the Privacy Officer. Violations may lead to disciplinary action under the disciplinary ladder in the Code of Conduct. Where an employee is unsure whether data is personal or whether a purpose is allowed, the employee should ask before proceeding.

14. Frequently Asked Questions

Can I use a customer's contact list in a spreadsheet on my laptop? Customer contact data is Confidential. Use it only inside approved systems; do not copy large exports to laptops without system owner approval.

Can I share an employee's phone number with another employee? Only if the individual has agreed or the sharing is needed for a work purpose such as an emergency contact tree.

Do we need a DPIA for a new HR tool? Yes, if it processes Restricted personal data of employees at scale. Raise it with the Privacy Officer before signing the contract.

15. Related Documents

See SEC-005 for classification and retention, SEC-010 for the incident response plan, SEC-011 for third-party security assessment, SEC-015 for logging and monitoring, CS-007 for customer data handling in support, and SEC-012 for awareness training.

16. Revision History

Version	Date	Change
4.1	2024-10-14	Added DPIA triggers for AI features
4.2	2025-03-03	Clarified processor role for Nexus customers
4.3	2025-09-15	Aligned breach handling with SEC-010